

Security+ 2.3 · Cross-Site Scripting (XSS)

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3 — Cross-Site Scripting (XSS) (8:34)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Cross-Site Scripting (XSS) injects malicious JavaScript into a third-party website that executes in the victim's browser using the victim's credentials (cookies, session). Three types: Reflected (via link — victim clicks), Persisted/Stored (stored in DB — affects all viewers), and DOM-based. Defenses: input sanitization/output escaping, HttpOnly cookies, and Content Security Policy (CSP).

High-Yield Core Concepts Tested on Exam

- XSS executes JavaScript in the VICTIM's browser — using THEIR cookies
- Persisted = stored in the database; Reflected = comes from the query string
- HttpOnly cookie: JavaScript cannot read it — mitigates XSS cookie theft
- DOM-based XSS manipulates the client-side DOM without server reflection
- CSP restricts which scripts can execute, reducing XSS impact

Exam Tips & Classic Scenarios

- 'malicious JavaScript runs in the victim's browser' = XSS
- 'Content Security Policy as defense' = XSS mitigation
- 'script stored in database affects all visitors' = Stored/Persisted XSS

Typical Exam Scenario: Scenario: 'a malicious comment on a forum executes a script for anyone who views the comment' = Stored (Persisted) XSS.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — Cross-Site Scripting (XSS))

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **WAF:** Web Application Firewall: Layer 7 security inspection appliance/service that inspects and filters HTTP/HTTPS payloads against OWASP Top 10 exploits such as SQL Injection, XSS, and CSRF.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Inject malicious script into a page to run in the browser of OTHER users:

- A)** XSS (Cross-Site Scripting)
- B)** CSRF
- C)** SQLi
- D)** Buffer overflow

2. Which network security device operates at the application layer (Layer 7) and can inspect HTTP/HTTPS content?

- A)** Traditional stateful firewall
- B)** Web Application Firewall (WAF)
- C)** Layer 2 switch
- D)** Hub

3. Corporate scenario (Cross-Site Scripting (XSS)): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'XSS runs JavaScript in the VICTIM's browser — with THEIR cookies.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: XSS runs JavaScript in the VICTIM's browser — with THEIR cookies...

4. Corporate scenario (Cross-Site Scripting (XSS)): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Persistent = stored in the database; reflected = comes from the query string'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Persistent = stored in the database; reflected = comes from the query string...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Cross-Site Scripting (XSS)): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'HttpOnly cookie: JavaScript cannot read — mitigates XSS stealing'. What is the best applicable recommendation or control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: HttpOnly cookie: JavaScript cannot read — mitigates XSS stealing...
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Cross-Site Scripting (XSS)): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'malicious JavaScript runs in the victim's browser' = XSS'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'malicious JavaScript runs in the victim's browser' = XSS...

7. Corporate scenario (Cross-Site Scripting (XSS)): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Content Security Policy as defense' = XSS mitigation'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'Content Security Policy as defense' = XSS mitigation...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Cross-Site Scripting (XSS)): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: 'malicious comment in a forum executes a script on whoever views the comment' = persistent XSS.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'malicious comment in a forum executes a script on whoever views the comment...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Cross-Site Scripting (XSS)): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'XSS runs JavaScript in the VICTIM's browser — with THEIR cookies.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: XSS runs JavaScript in the VICTIM's browser — with THEIR cookies...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Cross-Site Scripting (XSS)): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Persistent = stored in the database; reflected = comes from the query string.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Persistent = stored in the database; reflected = comes from the query string...
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — XSS (Cross-Site Scripting).

✓ **Why it is correct:** XSS (Cross-Site Scripting) is the vulnerability that allows the injection of malicious scripts (usually JavaScript) into web pages viewed by other users. In XSS, the attacker exploits the lack of input sanitization and/or output encoding so that the victim's browser executes the code in the context of the vulnerable application. There are three main types: stored (persistent), reflected (non-persistent), and DOM-based. The impact includes session cookie theft, session hijacking, malicious redirection, keylogging, and page defacement. The question describes exactly this scenario: 'Inject malicious script into a page to run in the browser of OTHER users', which is the precise definition of XSS according to SY0-701 objective 1.3 (application vulnerabilities) and 2.2 (application-based threats).

✗ **Why the others are wrong:**

- **CSRF:** CSRF (Cross-Site Request Forgery) is an attack that forces the victim's browser, already authenticated on a site, to perform unintended actions on that site (e.g., bank transfer, password change). The attacker does not inject script into the page; they trick the victim into having their browser send a forged request, leveraging the trust the site has in the victim's session cookie. Therefore, CSRF does not execute code in other users' browsers; it exploits the application's trust in the victim's browser. The question explicitly asks for script injection that runs in other users' browsers, which is not the CSRF mechanism.
- **SQLi:** SQL Injection (SQLi) is a technique of injecting malicious SQL commands into application inputs to manipulate the underlying database. The attacker can extract, modify, or delete data, bypass authentication, execute operating system commands, among others. The target is the database server, not other users' browsers. SQLi does not inject scripts that run in the victim's browser; it exploits the persistence layer. The question's description mentions 'run in the browser of OTHER users', which is characteristic of XSS, not SQLi.
- **Buffer overflow:** Buffer overflow is a memory corruption vulnerability where a program writes more data than the allocated buffer can hold, overwriting adjacent memory areas. This can lead to arbitrary code execution, system crash, or privilege escalation. The attack occurs in the vulnerable software process, not in other users' browsers. Although browsers can suffer buffer overflow, the described scenario is script injection into a web page for execution in third-party browsers, which is the specific domain of XSS. Buffer overflow is not a technique for injecting scripts into web pages.

2) B — Web Application Firewall (WAF).

✓ **Why it's correct:** A **Web Application Firewall (WAF)** is a security device that operates at the application layer (Layer 7 of the OSI model) and is designed to inspect HTTP/HTTPS traffic, protecting web applications against attacks such as SQL injection, cross-site scripting (XSS), cross-site request forgery (CSRF), among others. It analyzes the content of requests and responses, applying rules based on signatures or anomalous behavior. In the CompTIA Security+ (SY0-701) syllabus, WAF is explicitly cited as an application-layer security control to protect web servers. Therefore, it is the exact answer to the description.

✗ **Why the others are wrong:**

- **Traditional stateful firewall:** A traditional stateful firewall operates at the network and transport layers (Layers 3 and 4). It maintains a state table of connections and allows or blocks packets based on IP addresses, ports, and connection state. However, it does not inspect application-layer content (HTTP/HTTPS) and therefore cannot detect attacks like SQL injection or XSS. To inspect HTTP/HTTPS content, a next-generation firewall (NGFW) with deep packet inspection or a WAF

would be required. Thus, the traditional stateful firewall does not meet the requirement of operating at the application layer and inspecting content.

- *Layer 2 switch*: A Layer 2 switch operates at the data link layer (Layer 2) and is responsible for forwarding Ethernet frames based on MAC addresses. It lacks application-level traffic inspection capabilities, let alone HTTP/HTTPS content. Its function is to connect devices within the same local network, segmenting collision domains. It is not a Layer 7 security device and cannot inspect content. Therefore, it is incorrect.
- *Hub*: A hub is a physical layer (Layer 1) device that simply repeats electrical signals to all ports, without any forwarding intelligence or inspection. It does not operate at higher layers and offers no security functionality, much less HTTP/HTTPS content inspection. Hubs are obsolete and replaced by switches. Hence, it does not apply to the context of application-layer security.

3) D — Implement the corresponding solution: XSS runs JavaScript in the VICTIM's browser — with THEIR cookies....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cross-Site Scripting (XSS)): XSS runs JavaScript in the VICTIM's browser — with THEIR cookies. This highlights that XSS attacks execute malicious scripts in the context of the victim's session, allowing attackers to steal cookies, session tokens, or perform actions on behalf of the user. The correct answer directly reflects this concept by recommending the implementation of the corresponding solution.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: Persistent = stored in the database; reflected = comes from the query string....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cross-Site Scripting (XSS)): Persistent = stored in the database; reflected = comes from the query string.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) C — Implement the corresponding solution: HttpOnly cookie: JavaScript cannot read — mitigates XSS stealing....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cross-Site Scripting (XSS)): HttpOnly cookie: JavaScript cannot read — mitigates XSS stealing. This is a key defense against XSS attacks, as it prevents client-side scripts from accessing sensitive cookies.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: 'malicious JavaScript runs in the victim's browser' = XSS....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cross-Site Scripting (XSS)): 'malicious JavaScript runs in the victim's browser' = XSS.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: 'Content Security Policy as defense' = XSS mitigation....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cross-Site Scripting (XSS)): 'Content Security Policy as defense' = XSS mitigation. CSP restricts sources of executable scripts, mitigating XSS attacks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: Scenario: 'malicious comment in a forum executes a script on whoever views the comment....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cross-Site Scripting (XSS)): Scenario: 'malicious comment in a forum executes a script on whoever views the comment' = persistent XSS. Persistent (stored) XSS occurs when malicious script is permanently stored on the target server (e.g., in a database) and served to other users. The correct action is to implement the corresponding mitigation (e.g., input validation, output encoding, CSP).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: XSS runs JavaScript in the VICTIM's browser — with THEIR cookies....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cross-Site Scripting (XSS)): XSS runs JavaScript in the VICTIM's browser — with THEIR cookies. XSS exploits trust between a user and a vulnerable web application, allowing attackers to execute scripts in the victim's session context, steal cookies, session tokens, or perform actions on behalf of the user.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Persistent = stored in the database; reflected = comes from the query string....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Cross-Site Scripting (XSS)): Persistent = stored in the database; reflected = comes from the query string. Persistent XSS occurs when malicious script is permanently stored on the target server (e.g., in a database) and served to users. Reflected XSS occurs when the malicious script is immediately returned in the response, often via a query string parameter, without being stored.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.